Ficha Técnica de la Actividad

Unidad de Trabajo	**UT3:** Acceso a la información y control de privilegios
Resultado de Aprendizaje	**RA3:** Implanta métodos de control de acceso utilizando asistentes, herramientas gráficas y comandos del lenguaje del sistema gestor. *(Ponderación del módulo: 15%)*
Criterios Evaluados	**RA3:** CE 3.a, CE 3.b, CE 3.c, CE 3.d, CE 3.e, CE 3.f, CE 3.g, CE 3.h.
Temporalización y Entrega	6 horas lectivas • Entrega de un único archivo pdf con las actividades.

Requisito obligatorio de autoría y evidencias: Para dar por válida cualquier captura de pantalla, debe apreciarse claramente en la terminal interactiva de MySQL el prompt configurado en la UT1 (ej. `[alumno@localhost (liga)]>`) o la salida explícita de `SELECT CURRENT_USER(), CURRENT_ROLE();`. Las capturas anónimas, incompletas o recortadas invalidarán la actividad.

Bloque I: Fundamentos Teóricos y Principio del Menor Privilegio (RA3)

Actividad 1: Arquitectura del Catálogo y Niveles de Concesión CE 3.d, 3.h

Responde de manera sintética, rigurosa y justificada a las siguientes cuestiones técnicas en tu memoria:

1. **Principio del Menor Privilegio (PoLP):** Justifica técnicamente por qué una aplicación web que interactúa con la base de datos de la liga nunca debe conectarse al servicio utilizando la cuenta `root` ni disponer de privilegios globales (`*.*`).
2. **Mapeo en el Diccionario de Datos:** Investiga e indica qué tabla interna del catálogo `mysql` (`mysql.user` , `mysql.db` , `mysql.tables_priv` , `mysql.columns_priv` o `mysql.procs_priv`) se consulta y actualiza en cada una de las siguientes situaciones:
    - Un usuario ejecuta un `UPDATE` restringido exclusivamente sobre la columna `salario` de la tabla `jugadores` .
    - Un usuario recibe privilegios para crear vistas sobre cualquier tabla de la base de datos `liga` .
    - Un administrador ejecuta una sentencia de gestión global o altera variables del sistema.

3. **Ciclo RBAC en MySQL 8.0:** Explica por qué, tras conceder un rol a un usuario, la función `CURRENT_ROLE()` devuelve inicialmente el valor `NONE` al abrir una nueva sesión y qué instrucción administrativa permite automatizar su activación por defecto.

Bloque II: Provisión de Cuentas y Granularidad Escalar de Privilegios (RA3)

Actividad 2: Creación de Usuarios y Control de Acceso de Red CE 3.c, 3.h

Crea las siguientes cuentas de usuario delimitando con exactitud el host de conexión y las credenciales mediante el plugin de autenticación compatible:

1. `'usr_prensa'@'localhost'`: Conectado vía socket local con autenticación `mysql_native_password` y contraseña `PrensaPass_2026!`.
2. `'usr_delegado'@'localhost'`: Conectado localmente con autenticación `mysql_native_password` y contraseña `DelegadoPass_2026!`.
3. `'usr_rrhh'@'127.0.0.1'`: Conectado a través del loopback TCP/IP con autenticación `mysql_native_password` y contraseña `RrhhSecure_2026!`.

Adjunta captura consultando la tabla `mysql.user` donde se verifiquen los campos `user`, `host` y `plugin` para estas tres identidades.

Desde Opensuse no hemos podido conectarnos utilizando caching_sha2_password. Verifica si creamos un usuario utilizando caching_sha2_password se puede conectar. Si no lo puede hacer buscar como solucionarlo. Pista: normalmente es por utilizar un cliente antiguo o nos falta una librería (libmysqlclient-dev). Hacer una captura para comprobar el plugin del usuario, el error al intentar conectarse, la solución aplicada y como puede conectarse

Actividad 3: Concesión de Privilegios a Nivel de Tabla y Columna CE 3.d, 3.f

1. **Nivel de Tabla (Mesa de Control - `usr_delegado`):** Concede permisos para consultar (`SELECT`), insertar actas de partido (`INSERT`) y actualizar incidencias (`UPDATE`) exclusivamente sobre la tabla `estadisticas_jugador`. No debe disponer de permisos de borrado (`DELETE`) ni privilegios sobre el resto de tablas.
2. **Nivel de Columna (Recursos Humanos - `usr_rrhh`):** Aplica granularidad atómica de columna sobre la tabla física `jugadores`:

- Permiso `SELECT` únicamente en los campos: `id_jugador`, `nombre`, `apellido` y `salario`.
- Permiso `UPDATE` restringido estrictamente al campo: `salario`.

3. *(Nota técnica):* El usuario `usr_prensa` recibirá sus privilegios en el Bloque IV una vez desplegadas las vistas públicas.

Ejecuta e incluye la captura del comando `SHOW GRANTS FOR ...` para las cuentas `usr_delegado` y `usr_rrhh`.

Bloque III: Gestión Avanzada Mediante Roles (RBAC) y Ciclo de Vida (RA3)

Actividad 4: Despliegue de Roles y Activación Automática CE 3.e, 3.g, 3.h

Creación del Rol: Crea un rol administrativo denominado `rol_competicion_admin`:

```
CREATE ROLE IF NOT EXISTS 'rol_competicion_admin';
```

Dotación de Privilegios al Rol: Concede al rol permisos completos de manipulación (`SELECT`, `INSERT`, `UPDATE`, `DELETE`) sobre las tablas `equipos` y `partidos` de la base de datos `liga`. **Provisión y Enlace:** Crea la cuenta `'gestor_liga'@'localhost'` identificada con `mysql_native_password` y vincúlale el rol:

```
GRANT 'rol_competicion_admin' TO 'gestor_liga'@'localhost';
```

Activación por Defecto: Configura la cuenta para que el rol se active de manera automática en cada inicio de sesión:

```
SET DEFAULT ROLE 'rol_competicion_admin' TO 'gestor_liga'@'localhost';
```

Verificación de Sesión: Inicia sesión interactiva con el usuario `gestor_liga` y aporta una captura donde se visualice:

```
SELECT CURRENT_USER(), CURRENT_ROLE();
```

Debe apreciarse de forma inequívoca el rol `rol_competicion_admin`@`%` en estado activo.

Actividad 5: Delegación y Revocación Estricta de Accesos CE 3.d, 3.f, 3.g

1. Permite que el usuario `gestor_liga` pueda delegar privilegios de lectura sobre la tabla `equipos` a terceros utilizando la cláusula `WITH GRANT OPTION`.
2. **Revocación Total:** Ejecuta las sentencias necesarias para revocar el rol asignado a `gestor_liga` y retirar cualquier privilegio residual otorgado.
3. Demuestra con `SHOW GRANTS FOR 'gestor_liga'@'localhost';` que la cuenta ha quedado despojada de sus derechos operativos.

Bloque IV: Capa de Abstracción con Vistas y Sinónimos (RA3)

Actividad 6: Diseño de Vistas de Consulta y Ofuscación de Datos CE 3.a, 3.h

Implementa sobre la base de datos `liga` las siguientes vistas para ocultar información sensible y simplificar consultas analíticas:

1. **`v_jugadores_plantilla`:** Muestra el identificador del jugador, su nombre completo en un único campo (`nombre` y `apellido`), su puesto, altura, fecha de alta y el nombre del equipo al que pertenece.
   Requisito de confidencialidad: La columna `salario` debe quedar estrictamente excluida de la vista. Se deben omitir aquellos jugadores que no tengan equipo asignado.
2. **`v_partidos_completos`:** Lista los encuentros disputados mostrando la fecha, el nombre del equipo local, el resultado formateado como cadena de texto (ej. `"82 - 73"`), el nombre del equipo visitante y el nombre del árbitro que dirigió el partido.
3. **`v_estadisticas_anotadores`:** A partir de las tablas `estadisticas_jugador`, `jugadores` y `equipos`, muestra para cada jugador su nombre completo, el nombre de su equipo, el total de minutos disputados acumulados, la media de puntos por partido (redondeada a dos decimales) y el total de faltas cometidas.
4. **`v_capitanes_equipos`:** Relaciona de forma unívoca el nombre de cada equipo con el nombre completo de su capitán correspondiente, resolviendo la relación recursiva de la tabla `jugadores` mediante la clave `id_capitan`.

Adjunta capturas de la creación de las vistas y de la comprobación ejecutando un `SELECT * FROM vista LIMIT 5;` sobre cada una de ellas.

Actividad 7: Vistas Actualizables y Cláusula `WITH CHECK OPTION` CE 3.a, 3.h

Crea la vista actualizable `v_pivots_candidatos`:

```
CREATE OR REPLACE VIEW v_pivots_candidatos AS
SELECT id_jugador, nombre, apellido, puesto, altura, id_equipo
FROM jugadores
WHERE puesto = 'Pívot' AND altura >= 2.00
WITH CHECK OPTION;
```

Inserta un jugador válido a través de la vista:

```
INSERT INTO v_pivots_candidatos (nombre, apellido, puesto, altura, id_equipo)
VALUES ('Pau', 'Gasol', 'Pívot', 2.15, 1);
```

Aporta captura comprobando que el registro se ha persistido correctamente en la tabla física `jugadores`. Intenta insertar un registro que incumpla las condiciones de la vista (por ejemplo, con puesto `'Base'` o altura `1.92`):

```
INSERT INTO v_pivots_candidatos (nombre, apellido, puesto, altura, id_equipo)
VALUES ('Ricky', 'Rubio', 'Base', 1.92, 1);
```

Documenta mediante captura el error de bloqueo (**Error 1369**) y explica el papel de `WITH CHECK OPTION` para garantizar la coherencia lógica de los datos.

Actividad 8: Asignación de Permisos sobre Vistas y Emulación de Sinónimos CE 3.a, 3.b

1. **Emulación de Sinónimos:** En MySQL 8.0, donde no existe `CREATE SYNONYM`, crea la vista `arbitros_liga` que emule un sinónimo exacto 1:1 de la tabla física `arbitros`. Verifica su registro con `SHOW FULL TABLES WHERE Table_type = 'VIEW';`.
2. **Asignación al usuario de prensa:** Otorga a `'usr_prensa'@'localhost'` permiso de lectura exclusiva (`SELECT`) sobre las vistas públicas creadas: `v_jugadores_plantilla`, `v_partidos_completos` y `v_estadisticas_anotadores`.

3. Demuestra con `SHOW GRANTS FOR 'usr_prensa'@'localhost';` que la cuenta tiene acceso únicamente a estas vistas y no a las tablas base.

Actividad 9: Auditoría de Seguridad y Bastionado del Servidor CE 3.c, 3.g, 3.h

En esta actividad final auditarás la seguridad de tu servidor MySQL frente a posibles accesos no autorizados locales y de red. Para cada uno de los aspectos de la lista, debes comprobar en tu entorno si tu instalación es segura o presenta la incidencia.

Uso guiado de la Inteligencia Artificial (IA): Puedes utilizar asistentes de IA (ChatGPT, Gemini, etc.) como apoyo consultivo. Pídele ayuda formulando preguntas claras sobre:

1. **¿Cómo detectarlo?** Qué consulta SQL o comando de terminal Linux permite verificar el estado.
2. **¿Cómo solucionarlo?** Qué sentencia SQL, directiva en `my.cnf` o cambio de permisos en el sistema operativo corrige el problema si está vulnerable.

Recuerda contrastar críticamente las respuestas de la IA antes de aplicarlas en tu máquina para evitar dejar el servicio inoperativo.

Por cada punto del checklist, debes incluir en la memoria: el **resultado de la comprobación** .

1. Incidencias Graves (Riesgo Crítico / Compromiso Inmediato)

Fallos que permiten el control total del servidor, ejecución de comandos o acceso remoto no autenticado:

- **Acceso remoto del superusuario `root`:** Comprobar que `root` solo puede conectar desde `localhost` (o `127.0.0.1`) y jamás desde cualquier IP (`%`).
- **Usuarios anónimos:** Verificar que no existan cuentas con el nombre de usuario en blanco (`User = ''` en `mysql.user`).
- **Privilegios globales excesivos:** Comprobar que los usuarios de aplicaciones normales no tengan permisos administrativos (`SUPER` , `GRANT OPTION` , `FILE` , `SHUTDOWN`) ni acceso a `*.*` .
- **Escritura/Lectura arbitraria de ficheros (`secure_file_priv`):** Comprobar que no esté vacío (`""`). Debe apuntar a una ruta restringida o estar en `NULL` .
- **Servicio ejecutado como superusuario del sistema:** Verificar que el demonio `mysqld` se ejecuta bajo el usuario del sistema `mysql` y nunca como `root` de Linux.

- **Permisos del directorio de datos (`datadir`):** Comprobar que `/var/lib/mysql` tiene permisos restrictivos (`0700` o `0750`) y pertenece a `mysql:mysql`.

2. Incidencias Moderadas (Superficie de Exposición y Políticas de Acceso)

Debilidades de configuración que facilitan ataques dirigidos, fugas de credenciales o movimientos laterales:

- **Escucha de red innecesaria (`bind-address`):** Si la base de datos solo atiende a aplicaciones en la misma máquina, asegurar que escucha en `127.0.0.1` y no en todas las interfaces (`0.0.0.0`).
- **Existencia de la base de datos `test`:** Confirmar que se ha eliminado la base de datos `test` y sus permisos por defecto asociados (`test_%`).
- **Permisos de los ficheros de configuración:** Comprobar que `/etc/mysql/my.cnf` y sus subdirectorios tienen permisos seguros (`0640` o `0600`) y son propiedad de `root`.
- **Cifrado en tránsito (TLS/SSL):** Si se permiten conexiones de red, comprobar que `require_secure_transport = ON` o que se exige SSL a los usuarios remotos.
- **Filtrado por cortafuegos:** Asegurar mediante el cortafuegos del sistema (`ufw`, `firewalld` o `iptables`) que el puerto 3306 no está abierto a cualquier origen no autorizado.
- **Historial de comandos con contraseñas:** Comprobar que el archivo `~/.mysql_history` de los usuarios del sistema no almacena credenciales en texto claro (recomendar vaciado o enlace a `/dev/null`).
- **Registro general activado (`general_log`):** Verificar que está desactivado (`OFF`) en entornos reales para evitar guardar contraseñas y datos sensibles en texto claro.

3. Incidencias Leves (Buenas Prácticas y Defensa en Profundidad)

Ajustes recomendados para robustecer la robustez operativa, auditoría y resistencia a ataques de fuerza bruta:

- **Componente de validación de contraseñas:** Comprobar si está activo `validate_password` con directivas mínimas de longitud y complejidad.
- **Política de expiración y bloqueo de cuentas:** Verificar si están configurados límites de intentos fallidos (`FAILED_LOGIN_ATTEMPTS`) y caducidad periódica.

- **Plugin de autenticación seguro:** Asegurar el uso de mecanismos modernos (como `caching_sha2_password`) y evitar plugins desaconsejados u obsoletos.
- **Enlaces simbólicos desactivados:** Verificar que la opción `symbolic-links = 0` (o `skip-symbolic-links`) está habilitada.
- **Permisos del registro de errores:** Verificar que el archivo indicado en `log_error` solo puede ser leído por el usuario `mysql` o administradores (`0640`).
- **Perfil de confinamiento activo:** Comprobar que el servicio cuenta con perfil en modo *enforce* mediante AppArmor o SELinux.
- **Trazabilidad y auditoría:** Identificar la presencia o posibilidad de activar plugins de auditoría para registrar intentos de acceso y cambios de permisos (DCL).

Bloque V: Matriz de Evidencias y Auditoría de Seguridad (RA3)

Actividad 10: Verificación Cruzada (Operaciones Autorizadas vs. Denegadas) CE 3.c, 3.d, 3.f, 3.h

Para comprobar que el Principio del Menor Privilegio se cumple rigurosamente y no existen vías de escalada de privilegios, aporta en tu memoria técnica las capturas emparejadas de las siguientes pruebas:

Usuario Conectado	Prueba Positiva (Acceso Autorizado)	Prueba Negativa (Bloqueo / Access Denied)
`usr_prensa`	Consulta satisfactoria sobre `v_jugadores_plantilla`.	Intento de consultar la tabla base (`SELECT * FROM liga.jugadores;`) que arroje el **Error 1142**.
`usr_delegado`	Inserción satisfactoria de un registro estadístico en `estadisticas_jugador`.	Intento de borrado de registros (`DELETE FROM liga.estadisticas_jugador;`) que arroje el **Error 1142**.
`usr_rrhh`	Actualización satisfactoria del salario de un jugador.	Intento de consulta sobre columnas restringidas (`SELECT puesto, altura FROM liga.jugadores;`) con denegación a nivel de campo.
`gestor_liga`	Consulta exitosa de tablas `equipos` y `partidos` con el rol activo.	Intento de inserción en `partidos` tras revocar el rol que demuestre la pérdida del permiso.

Rúbrica de Calificación

Bloque Evaluado	Criterios	Excelente (100%)	Aceptable (60%)	Insuficiente (0%)	Peso
Bloque I: Fundamentos y Diccionario de Datos	RA3: CE 3.d, 3.h	Justifica con precisión el PoLP, identifica con exactitud las tablas del catálogo `mysql.*` y describe en detalle el mecanismo RBAC y sincronización.	Responde a las cuestiones pero comete imprecisiones en el catálogo interno o en la activación de roles.	Respuestas ausentes, erróneas o sin base técnica.	**15%**
Bloque II: Provisión de Usuarios y Granularidad	RA3: CE 3.c, 3.d, 3.f, 3.h	Configura usuarios con plugins adecuados y aplica granularidad milimétrica a nivel de tabla y columna salarial.	Crea los usuarios pero incurre en exceso de privilegios o falla al acotar permisos a nivel de columna.	No define cuentas o recurre a asignaciones masivas tipo `ALL PRIVILEGES`.	**25%**
Bloque III: Gestión de Roles (RBAC) y Ciclo de Vida	RA3: CE 3.e, 3.g, 3.h	Ciclo RBAC impecable: crea rol, asigna permisos, vincula usuario, automatiza activación por defecto y revoca accesos limpiamente.	Configura el rol pero no define la activación automática o presenta dudas en el proceso de revocación.	No implementa roles o no demuestra el cambio de contexto en la sesión interactiva.	**15%**
Bloque IV: Abstracción, Vistas y Sinónimos	RA3: CE 3.a, 3.b, 3.h	Vistas perfectamente implementadas sin exponer datos sensibles, demuestra el bloqueo de `WITH CHECK OPTION` y emula el sinónimo con éxito.	Crea las vistas pero descuida la cláusula `CHECK OPTION` o presenta errores leves en las uniones relacionales.	Vistas no funcionales, sintaxis errónea o exposición indebida de salarios.	**25%**
Bloque V: Auditoría, Evidencias y Memoria Técnica	RA3: CE 3.c al 3.h	Documento PDF impecable con prompt identificativo visible en todas las capturas; pruebas de denegación exhaustivas y script SQL limpio adjunto.	Memoria completa pero omite alguna prueba de bloqueo denegado o el prompt resulta ilegible en capturas puntuales.	Capturas anónimas o sin prompt, ausencia del script SQL o falta de evidencias de bloqueo por permisos.	**20%**